

Report Laboratori Cybersecurity

Esercizio 1, Esercizio 2, Bonus Nmap, Bonus SQL Injection

Report 1 - Esercizio 1: Uso di Windows PowerShell

Obiettivo

L'obiettivo dell'esercizio era esplorare alcune funzioni di base di Windows PowerShell, confrontare i comandi del Prompt dei Comandi con quelli di PowerShell, analizzare alcuni cmdlet, usare il comando netstat e svuotare il Cestino tramite console.

Parte 1: Accesso a PowerShell

Ho avviato Windows PowerShell dal menu Start cercando "PowerShell". Successivamente ho aperto anche il Prompt dei Comandi per confrontare il comportamento di alcuni comandi nelle due console.

PowerShell si presenta come una console più avanzata rispetto al Prompt dei Comandi, perché permette sia di eseguire comandi tradizionali sia di usare cmdlet specifici per l'amministrazione del sistema.

Parte 2: Confronto tra comandi del Prompt e PowerShell

È stato eseguito il comando:

```
dir
```

Il comando dir mostra il contenuto della directory corrente, quindi file e cartelle presenti nel percorso in cui ci si trova.

In PowerShell, però, dir non è il comando reale principale, ma un alias. Usando:

```
Get-Alias dir
```

si scopre che dir corrisponde al cmdlet:

```
Get-ChildItem
```

Quindi il comando PowerShell effettivo per visualizzare file e directory è Get-ChildItem.

Sono stati provati anche comandi comuni come:

```
ping  
cd  
ipconfig
```

Questi comandi funzionano anche in PowerShell, perché PowerShell mantiene compatibilità con molti comandi del Prompt dei Comandi.

Parte 3: Cmdlet PowerShell

I cmdlet sono comandi nativi di PowerShell costruiti secondo la forma verbo-nome, ad esempio:

```
Get-ChildItem  
Clear-RecycleBin  
Get-Process  
Get-Service
```

Questa struttura rende i comandi più leggibili e coerenti. Ad esempio, Get-ChildItem significa "ottieni gli elementi figli", cioè mostra gli elementi contenuti in una directory.

Parte 4: Uso di netstat

È stato eseguito il comando:

```
netstat -h
```

Questo comando mostra le opzioni disponibili per netstat.

Successivamente è stato usato:

```
netstat -r
```

Il comando mostra la tabella di routing del sistema. Da questa tabella è possibile individuare il gateway IPv4 predefinito, cioè l'indirizzo IP del router utilizzato per raggiungere reti esterne.

È stato poi eseguito:

```
netstat -abno
```

Questo comando mostra le connessioni TCP attive, le porte in ascolto, gli indirizzi locali e remoti, lo stato della connessione e il PID del processo associato. Il PID può essere confrontato con Gestione Attività nella scheda Dettagli, così da identificare quale processo sta usando una determinata connessione.

Parte 5: Svuotare il Cestino

È stato usato il comando:

```
Clear-RecycleBin
```

Dopo la conferma, i file presenti nel Cestino vengono eliminati definitivamente. Questo dimostra come PowerShell possa essere usato anche per operazioni normalmente eseguite tramite interfaccia grafica.

Conclusione

PowerShell è uno strumento molto utile per amministrare Windows. Rispetto al Prompt dei Comandi offre comandi più potenti, alias compatibili con comandi tradizionali e cmdlet pensati per automatizzare attività di sistema. Durante l'esercizio ho imparato a usare comandi base, analizzare connessioni di rete e gestire risorse di sistema tramite console.

Report 2 - Esercizio 2: Studio IOC e analisi di minacce con Any.Run

Obiettivo

L'obiettivo dell'esercizio era analizzare un link tramite Any.Run e descrivere le minacce osservate in un breve report. Any.Run è una sandbox online usata per eseguire file o URL sospetti in un ambiente controllato, osservando il comportamento del possibile malware.

Analisi generale

Durante l'analisi di un link sospetto, è importante osservare diversi indicatori di compromissione, chiamati IOC. Gli IOC possono includere indirizzi IP, domini, URL, file scaricati, processi avviati, chiavi di registro modificate, connessioni di rete e comportamenti anomali del sistema.

Nel contesto dell'esercizio, il link analizzato con Any.Run permette di visualizzare il comportamento della minaccia in tempo reale o tramite un report già registrato.

Possibili minacce individuabili

- Connessioni verso domini sospetti
- Download di file eseguibili
- Creazione di processi anomali
- Modifica di file di sistema
- Tentativi di persistenza
- Comunicazione con server di comando e controllo
- Raccolta di informazioni dal sistema

Se il file o il link analizzato apre connessioni verso server esterni, questi indirizzi possono essere considerati indicatori utili per il blocco tramite firewall, proxy o sistemi di sicurezza.

Indicatori di compromissione

- URL sospetto analizzato
- Dominio coinvolto
- Indirizzi IP contattati
- File eventualmente scaricati
- Hash dei file
- Processi creati
- Eventuali modifiche al sistema

Queste informazioni aiutano un analista di sicurezza a capire se la minaccia è già presente in altri sistemi della rete.

Impatto della minaccia

Una minaccia analizzata in sandbox può avere diversi obiettivi. Può tentare di rubare credenziali, installare malware aggiuntivo, creare persistenza sul sistema o comunicare con un server esterno. Anche un semplice collegamento web può essere pericoloso se porta a una pagina di phishing, a un exploit kit o al download automatico di un file malevolo.

Contromisure consigliate

- Bloccare domini e IP sospetti
- Non aprire link provenienti da fonti non affidabili
- Aggiornare browser e sistema operativo

- Usare antivirus e sistemi EDR
- Analizzare allegati e URL in sandbox prima dell'apertura
- Formare gli utenti sul phishing

Conclusione

L'analisi con Any.Run è utile perché consente di osservare il comportamento di una minaccia senza compromettere il proprio computer. Attraverso gli IOC raccolti è possibile capire come agisce il malware o il link sospetto e applicare misure di difesa sulla rete aziendale.

Report 3 - Bonus 1: Esplorazione e scansione con Nmap

Obiettivo

L'obiettivo del bonus era esplorare l'uso di Nmap, leggere la pagina manuale del comando e usare alcune opzioni per scansionare host locali, una rete LAN e il server remoto scanme.nmap.org.

Nmap è uno strumento usato per la scoperta di host, la scansione delle porte e l'analisi dei servizi attivi su un sistema.

Parte 1: Esplorazione della pagina manuale

È stato aperto il manuale con:

```
man nmap
```

Nel manuale è stato cercato il termine `example` per visualizzare esempi pratici di utilizzo. L'esempio osservato utilizza il comando:

```
nmap -A -T4 scanme.nmap.org
```

L'opzione `-A` abilita funzioni avanzate come il rilevamento del sistema operativo, il rilevamento delle versioni dei servizi, l'esecuzione di script e il traceroute.

L'opzione `-T4` imposta una velocità di scansione più aggressiva e rapida, adatta a reti stabili.

Parte 2: Scansione del localhost

È stato eseguito:

```
nmap -A -T4 localhost
```

Dai risultati risulta aperta la porta:

```
21/tcp open ftp
```

Il servizio associato è FTP, con software `vsftpd`. Questo indica che sulla macchina locale è presente un servizio FTP attivo e raggiungibile.

Parte 3: Scansione della rete locale

Dopo aver verificato l'indirizzo IP della VM con:

```
ip address
```

è stata individuata la rete, ad esempio:

```
10.0.2.0/24
```

Successivamente è stata eseguita una scansione della LAN:

```
nmap -A -T4 10.0.2.0/24
```

Il risultato ha mostrato più host attivi sulla rete. Nell'esempio del laboratorio risultano 4 host attivi.

Tra i servizi rilevati compaiono:

```
21/tcp FTP
22/tcp SSH
23/tcp Telnet
```

Queste informazioni sono utili per capire quali sistemi sono presenti nella rete e quali servizi espongono.

Parte 4: Scansione di scanme.nmap.org

E stata eseguita la scansione:

```
nmap -A -T4 scanme.nmap.org
```

L'indirizzo IP del server rilevato e:

```
45.33.32.156
```

Le porte aperte individuate sono:

```
22/tcp open  ssh
80/tcp open  http
9929/tcp open nping-echo
31337/tcp open tcpwrapped
```

Alcune porte risultano filtrate, ad esempio 25/tcp, 135/tcp, 139/tcp, 445/tcp, 593/tcp e 4444/tcp.

Il sistema operativo rilevato e Linux. Il servizio HTTP risulta gestito da Apache, mentre SSH risulta attivo sulla porta 22.

Riflessione sulla sicurezza

Nmap e molto utile per la sicurezza di rete perche permette agli amministratori di individuare porte aperte, servizi non necessari, configurazioni deboli e host sconosciuti. Può essere usato per verificare se una rete e esposta a rischi.

Tuttavia, Nmap può essere usato anche da attaccanti per fare ricognizione prima di un attacco. Un aggressore può usarlo per trovare servizi vulnerabili, sistemi non aggiornati o porte aperte da sfruttare.

Conclusione

L'esercizio ha mostrato come Nmap sia uno strumento fondamentale per l'analisi di rete. Usato in modo autorizzato, aiuta a migliorare la sicurezza. Usato senza permesso, invece, può diventare parte di un'attività malevola di ricognizione.

Report 4 - Bonus 2: Analisi di un attacco SQL Injection con Wireshark

Obiettivo

L'obiettivo del laboratorio era analizzare un file PCAP con Wireshark per osservare un attacco SQL Injection contro un database MySQL. L'analisi si concentra sul traffico HTTP registrato durante l'attacco.

Parte 1: Apertura del file PCAP

E' stato aperto Wireshark e caricato il file SQL_Lab.pcap. Il file contiene traffico catturato durante un attacco durato diversi minuti.

Dall'analisi iniziale si notano due indirizzi IP principali coinvolti:

```
10.0.2.4  
10.0.2.15
```

L'indirizzo 10.0.2.4 rappresenta la sorgente dell'attacco, mentre 10.0.2.15 rappresenta la vittima, cioè il server web vulnerabile.

Parte 2: Inizio dell'attacco

Nel traffico HTTP e' stata selezionata una richiesta GET e tramite Follow > HTTP Stream e' stato possibile visualizzare il contenuto della comunicazione.

L'attaccante ha inserito nel campo di ricerca UserID il valore:

```
1=1
```

Questa condizione e' sempre vera. Invece di restituire un messaggio di errore, l'applicazione ha risposto con dati presenti nel database. Questo dimostra che l'applicazione e' vulnerabile a SQL Injection.

Tra le informazioni mostrate compaiono utenti come admin. Questo significa che l'attaccante e' riuscito a ottenere dati dal database manipolando la query SQL.

Parte 3: Continuazione dell'attacco

L'attaccante ha poi usato una query piu' avanzata:

```
1' or 1=1 union select database(), user()#
```

Questa query sfrutta UNION SELECT per estrarre informazioni aggiuntive dal database.

Dalla risposta dell'applicazione sono state ottenute informazioni importanti:

```
Nome del database: dvwa  
Utente del database: root@localhost
```

Queste informazioni sono molto sensibili perche' aiutano l'attaccante a capire quale database e' in uso e con quali privilegi viene eseguita la connessione.

Parte 4: Informazioni di sistema

In una fase successiva l'attaccante ha usato una query per ottenere la versione del database:

```
1' or 1=1 union select null, version()#
```

La risposta mostra la versione:

```
5.7.12-0ubuntu1.1
```


Sapere la versione del database puo aiutare un attaccante a cercare vulnerabilita specifiche per quella versione di MySQL o MariaDB.

Parte 5: Informazioni sulle tabelle

L'attaccante sa che nel database esistono molte tabelle SQL e prova a individuarle. Per questo usa una query di enumerazione contro INFORMATION_SCHEMA:

```
1' or 1=1 union select null, table_name from information_schema.tables#
```

Questa query restituisce molti nomi di tabelle presenti nel database e nelle aree di sistema, producendo un output molto lungo. Tra le tabelle individuate compare anche la tabella users, che e particolarmente interessante perche puo contenere nomi utente e password.

La domanda della schermata chiede cosa farebbe il comando modificato:

```
1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE  
table_name='users'?
```

Questo comando non elencherebbe piu tutte le tabelle, ma filtrerebbe il risultato mostrando solo i nomi delle colonne della tabella users. In pratica aiuterebbe l'attaccante a scoprire quali campi contiene quella tabella, ad esempio colonne come user, password, first_name o last_name. Questo rende l'attacco piu mirato, perche consente di capire esattamente quali colonne interrogare per estrarre credenziali.

Parte 6: Estrazione degli hash delle password

Nella fase finale l'attaccante usa una query per estrarre utenti e hash delle password dalla tabella users:

```
1' or 1=1 union select user, password from users#
```

La risposta contiene diversi utenti e hash. L'hash indicato nella domanda e:

```
8d3533d75ae2c3966d7e0d4fcc69216b
```

Questo hash appartiene all'utente 1337. Usando un servizio di cracking o un dizionario di hash noti, la password in chiaro associata risulta:

```
charley
```

Questo passaggio mostra il rischio piu grave dell'attacco: non solo l'aggressore riesce a leggere la struttura del database, ma riesce anche a estrarre credenziali che potrebbero essere riutilizzate per accedere ad altri sistemi.

Rischi dell'attacco

- Furto di dati
- Lettura di credenziali
- Modifica o cancellazione di record
- Accesso non autorizzato
- Enumerazione di database, tabelle e colonne
- Compromissione dell'applicazione web

Nel laboratorio, l'attaccante e riuscito a ottenere nomi utente, nome del database, utente del database, versione del sistema, nomi di tabelle, colonne della tabella users e hash delle password.

Domande di riflessione

1. Qual e il rischio per le piattaforme che utilizzano il linguaggio SQL?

Il rischio principale è che un input non controllato permetta a un attaccante di modificare la query SQL originale. In questo modo l'aggressore può leggere dati riservati, bypassare il login, ottenere credenziali, modificare record, cancellare informazioni o raccogliere dettagli tecnici utili per un attacco successivo. La gravità dipende dai privilegi dell'utente database e dal tipo di dati gestiti dall'applicazione.

2. Quali metodi possono prevenire gli attacchi SQL Injection?

- Usare query parametrizzate o prepared statements, evitando di concatenare direttamente l'input dell'utente nelle query SQL.
- Validare e filtrare gli input dell'utente, accettando solo il formato previsto per ogni campo.
- Applicare il principio del minimo privilegio all'utente del database, in modo che l'applicazione non usi account amministrativi come root.
- Disabilitare funzionalità non necessarie del database e non mostrare messaggi di errore dettagliati agli utenti.
- Usare un Web Application Firewall e monitorare le query sospette nei log.
- Aggiornare database, framework e applicazioni per ridurre vulnerabilità note.

Conclusione

L'analisi del file PCAP ha mostrato chiaramente come un attacco SQL Injection possa essere individuato nel traffico di rete. Wireshark permette di seguire il flusso HTTP e osservare le query inviate dall'attaccante. L'esercizio dimostra l'importanza della validazione degli input, dell'uso di query sicure e della corretta gestione dei privilegi del database per proteggere applicazioni e dati sensibili.